PROJECT 1 + PROJECT 2 → PROJECT 3

Engineering handoff and working agreement | Clinical Co-Pilot / AgentForge / OpenEMR | Prepared October 17, 2026

Purpose: Bring a new ChatGPT conversation up to speed without requiring the user to repeat two projects. This is

historical context, not the Week 3 PRD. The Week 3 document must be read and scoped independently.

1. Status at handoff - important distinctions

- Project 1: Completed engineering scope, 5/5 functional acceptance; committed to main in the original handoff.
- Project 2: Completed applicable engineering PRD requirements per final read-only audit; 5/5 public browser scenarios passed, real Sonnet/VLM tested, Week 2 CI verified on GitHub and pull request.
- Merge: Week 2 PR #1 in the user fork targeted main, with 14 commits, 203 changed files, 38/38 PR checks passed and no conflicts. The user subsequently showed the main branch with merge commit efb66b5 (GitHub: "Merge pull request #1 from Sabeehq11/week2-agentforge"). A post-merge main-branch check appeared pending in the screenshot; no subsequent green result was supplied.
- Do not confuse repos: user fork github.com/Sabeehq11/openemr-base-clean versus upstream

Gauntlet-HQ/openemr-base-clean . A wrong PR initially targeted upstream (35 commits / 372 files); correct PR targeted user fork (14 commits / 203 files).

- Week 3: Not started in this handoff. User will attach the actual Project 3/Week 3 PRD. Do not infer requirements from Weeks 1-2.

2. Project 1 baseline (preserved from original handoff)

Repo and original completion: github.com/Sabeehq11/openemr-base-clean fork; branch main; Project 1 final pushed

commit fc93ff1642851e3df5b3e491c5ea2a2658a13823 ; earlier checkpoint 38c7cfc . Original handoff dated October

13, 2026.

Architecture: Local OpenEMR with seeded synthetic patient records and PHP embedded Clinical Co-Pilot module

(oe-module-copilot). UI HTTP localhost:8300 / self-signed TLS localhost:9300 . FastAPI agent under agent/ at

localhost:8400 ; separate stub/load agent on 8401. Original demo agent uses persistent Docker volume

agent_agent_data for trace/audit SQLite. Real model OpenRouter anthropic/claude-sonnet-4.5 .

Request path: OpenEMR chart → signed patient-scoped request → authorization → classifier → FHIR/tools + cached

snapshot (reauthorized each turn) → model when appropriate → strict citation verification and deterministic clinical

rules → cited streamed UI response. Dose/treatment advice can be refused deterministically before model calls.

Delivered: Previsit briefs, chart-change questions, multi-turn medication follow-ups, strict typed FHIR tools,

patient-specific physician ACL, citation/source views, unsupported-claim withholding, dose/treatment refusal,

monitoring evidence-gap flags, HMAC audit chain, correlation IDs, cost/performance dashboard (15-second refresh;

p50/p95; request/error counts; inflight/shed; retries; tool outcomes; three alerts).

Monitoring: agent/app/monitoring.py version 2026-10-v1: warfarin/INR, ACE inhibitors/potassium and renal function,

metformin/renal function, statins/lipids. Only report missing evidence from successfully retrieved labs; no unsupported

inference or clinical dosing advice.

Verification: 522 offline tests, 60/60 stub evaluations; live 10/10; signed Bruno requests passed twice; 10-concurrent

real-model p95 ~20.3s; 50-concurrent stub/mock exposed OpenEMR authorization saturation, not 50-user success.

Manual 5/5: cited Maria Alvarez brief; four active medications and monitoring gaps; warfarin dose refusal;

unauthorized physician denial; dashboard/alerts/audit integrity.

Operational gotchas: Original agent container is image-baked: edits require Docker Compose rebuild/recreate,

preserving volume, then /ready and audit verification. Safari normal-mode localhost cookie issue previously caused

HTTP 400/blank UI; Private Browsing worked. Dashboard uses Basic admin plus ignored DASHBOARD_TOKEN , not

OpenEMR credentials. Live integration tests need actual DB_ROOT_PASS ; default root was incorrect.

Security and costs: Ignored secrets include agent/.env , deploy/tunnel/.env , config.local.php and agent data. Original

handoff noted credentials accidentally printed in Cursor conversation but not shown in GitHub; rotate if appropriate.

Project 1 recorded cost subtotal $0.9901 (not lifetime total), and manual chats add costs. Live eval runner has locking

to prevent duplicate concurrent runs.

3. Project 2: objective and delivered architecture

Project: AgentForge Clinical Co-Pilot Week 2 - Multimodal Evidence Agent. Extended Week 1 rather than rebuilding.

C0-C5 were assistant-created internal checkpoints, NOT official PRD milestones. Cohort-specific public submissions,

demo video and social post do not apply to this user.

- Multimodal ingest: Server-side attach/extract for lab PDFs and intake forms. Source documents stored in OpenEMR. Strict JSON contracts and derived facts; supported numeric lab values written via PHP LabRecordWriter.php while intake remains derived in w2_facts . Unsupported values withheld. Duplicate SHA-256 upload handling rebinds citations to current patient-owned OpenEMR document ID, without repeating VLM calls or duplicate chart rows.
- Contracts: agent/contracts/w2/ includes frozen, extra-forbid Citation, LabPdfExtraction and IntakeFormExtraction. Raw VLM output is separate from validated final models and cannot choose source IDs.
- Evidence retrieval: Hybrid BM25 + dense embeddings + Cohere rerank under agent/app/w2/rag/ ; offline stubs for CI. Retrieval fallbacks, bounded retry/timeouts and inflight/shedding substitute for a full queue/circuit breaker, documented in architecture.
- Agent orchestration: Inspectable hand-written supervisor graph with typed handoffs and two workers (intake-extractor, evidence-retriever), permitted instead of LangGraph by PRD. Correlation IDs, parent spans, tokens, estimated costs, retrieval hits, confidence and evaluation outcomes are recorded without raw PHI.
- Citations/UI: Source-type grouping for patient/problem/medication/recent labs/historical flags/documents/guidelines. PDF page bbox overlay highlights actual lab lines; safe HTML entity decoding without rendering untrusted markup. Clinical contradictions from seeded records are flagged as historical rather than silently corrected.
- API/security: Signed patient-scoped access, session ACL and source proxy, OpenAPI 3 contract tests, Bruno Week 2 collection, separate /health and /ready, dashboard metrics/alerts, PHI scans, and recovery plan.

4. Project 2: real-model environment and browser acceptance

Isolation: Original agent-agent-1 and Docker volume agent_agent_data were preserved. Real-model isolated container

agent-real on localhost 127.0.0.1:8402 , network name http://agent-real:8400 , using loadtest/docker-compose.real.yml

and ignored agent/.env OpenRouter key; model anthropic/claude-sonnet-4.5 , W2_USE_STUB_VLM=false . Isolated bind

data tmp/agent-real-data . OpenEMR gitignored config.local.php temporarily routed module to real agent; never

assume routing remains so after restart.

Public demo: A Cloudflare quick tunnel exposed OpenEMR only, at the time

https://furnished-announced-prominent-acres.trycloudflare.com . This URL is ephemeral and must be rediscovered;

never present it as a durable live endpoint. Agent health routes were not publicly exposed and real-agent port was

localhost-bound. OpenEMR original agent was not restarted.

Real lab PDF: 5/5 rows extracted and supported with page-one boxes: HbA1c 7.9%, creatinine 1.8 mg/dL, glucose 142

mg/dL, LDL 96 mg/dL, potassium 4.1 mmol/L; collection date 2026-09-12. LDL direct LOINC was appropriately withheld

when source did not specify direct. One extraction 10.7s, agent-recorded $0.017421. Earlier doc-grounded follow-up

~19.5s, $0.036795. Initial isolated clinical chat ~24.7s, $0.059277.

Browser manual acceptance 5/5: (1) Maria Alvarez (patient 100) previsit brief with chart/guideline/document citations

and historical flags; (2) chart-change/guideline clinical chat grounded and readable; (3) PDF upload 5/5 rows and no

duplicate chart writes; (4) clicked A1c and glucose source chips to actual PDF with correct orange highlights; (5) user

copilot_doc_a denied access to patient 101 belonging to copilot_doc_b . Browser screenshots were inspected in the

prior conversation.

Seeded-data caution: Some historical 2024 labs are intentionally anomalous (e.g., creatinine 44 mg/dL with no stored

high flag, glucose 13.1 mg/dL marked high, LDL 168.2 marked low, A1c 6.3 marked high). Do not rewrite clinical

fixtures to make them look plausible; surface contradictions.

5. Project 2: tests, CI, security, backup

Golden evaluation: 50/50 boolean gate passed; injected citation, safety and PHI faults failed closed. Full free suite

later reported 932 passed, 1 skipped, 30 live deselected. 17 tunnel lifecycle tests passed on macOS and Ubuntu 24.04

after zombie-process handling; no weakened assertions. Local first-party Python coverage 95.14% of 3,994

statements, 194 missed, threshold 90%. app/w2/vlm.py 46% offline coverage because live vision calls are stubbed;

live VLM separately smoke-tested.

CI workflow: .github/workflows/w2-eval-gate.yml on PRs without restrictive path filter; Ruff E9/F63/F7/F82

syntax/undefined checks; mypy via scripts/w2/mypy_gate.py with 16 existing baseline errors and zero new; pytest-cov

on app/contracts with 90% floor; Bandit medium+ severity/confidence on agent app/contracts; pip-audit; secret scan;

PHP php -l ; JS node --check ; golden gate; workflow-scope guard. CI tooling pinned in scripts/w2/ci-requirements.txt .

Limits: baseline mypy errors remain, security scan does not cover all PHP/JS, upstream Semgrep targets other branch;

required branch-protection status setting was not independently confirmed.

Actual GitHub verification: Week 2 push W2 Eval Gate #4 success (commit 0557e6d); final docs W2 Eval Gate #5

success (commit 9f036541cf95e896db065e0c652afb75627b03c2). Correct fork PR #1 had 38/38 checks passed and

no conflicts before merge. A new post-merge main check was shown pending, not confirmed green in supplied

evidence.

Security/recovery: Five weak stock OpenEMR accounts disabled with approval. Read-only SQLite copy of original live

derived-data volume integrity-checked and restore-tested without altering live; five documents on volume. Golden

evaluation dataset rebuildable from repo. Backup procedure and 24h RPO require manual backup execution; do not

claim nightly scheduler is deployed. No raw PHI in logs/traces/evals; access controls tested. Clinical outputs are

evidence support, not medical clearance.

6. Project 2: performance, costs, evidence limitations

- Real chat: n=9, p50 19.8s, p95 24.6s, mean recorded cost $0.0498. Retrieval n=11, p50 867ms, p95 2.6s, under 3s retrieval target.
- Extraction: One end-to-end sample 10.7s, $0.0174, VLM ~97% of extraction time. Ingestion p95 NOT measured with n=1; do not invent one.
- Bottleneck: Chart-facts loop p50 ~14.2s (~70% of a 20s chat); retrieval not the main bottleneck. Week 1 real brief p50 ~14.5s / $0.0246; Week 2 chat ~5s slower / ~2x cost.
- Resources: Isolated idle 0.3% CPU / 78 MiB; stub path 98% of one core / 118 MiB / 97 calls per second until client stopped. These are NOT real-model concurrency figures.
- Costs: Two additional direct VLM requests ~$0.0195; recorded evidence spend $0.4854. Actual OpenRouter account total unverified because key is shared; embedding and

rerank charges excluded from trace cost. Projection ~$21.90 per physician per month for Week 2 vs ~$10.80 Week 1, plus ~$0.77 documents, assumption-based, not a bill.

- Limitations disclosed: No ingestion p95, real-call CPU/memory profile, real concurrent throughput, or verified embedding/rerank/provider-account totals. Final read-only PRD audit judged report compliant despite transparent limits; do not reopen these as new requirements absent Week 3 need.

7. Git state and artifacts at Project 2 close

Fork: https://github.com/Sabeehq11/openemr-base-clean . Project 2 branch week2-agentforge retained. Correct PR #1

merged into fork main; screenshot shows merge commit efb66b5 and fork main 36 commits ahead of Gauntlet-HQ

upstream main. The branch was not deleted. New Project 3 branch should be created from updated fork main, not

upstream and not Week 2 branch.

Final Week 2 docs commit: 9f036541cf95e896db065e0c652afb75627b03c2 updated four files:

docs/week2/PERFORMANCE.md , docs/week2/checkpoints/C5-deploy-and-defend.md , W2_ARCHITECTURE.md ,

docs/week2/ROADMAP.md . Corrected stale "real-model pending" status. README broken C5 link fixed earlier.

Uncommitted local-only files at final push: Regenerated evals/results/w2-golden-latest.json , w2-golden-latest.md ,

gate-latest.md and modified docs/week2/DEMO_SCRIPT.md . These were not included in final docs commit.

agent/.coverage added to gitignore. Inspect local git status before starting Week 3; do not blindly git add -A, reset, or

discard the files.

Key paths: agent/app/w2/ , agent/contracts/w2/ , agent/tests/ , evals/ , loadtest/ , scripts/w2/ , docs/week2/ ,

docs/week2/openapi.yaml , docs/api-collection/copilot/w2/ , .github/workflows/w2-eval-gate.yml ,

loadtest/docker-compose.real.yml , PHP module oe-module-copilot .

8. Working rules - MUST apply in Project 3

Communication and prompt length

- Keep Cursor prompts short and focused. Simple tasks deserve one or two clear sentences. Do not generate giant multi-clause prompts for trivial fixes. Longer prompts are appropriate only when the scope genuinely demands it.

- Speak plainly, conversationally and directly. User calls assistant "bro"; avoid corporate fluff, excessive reassurance, needless repeated apologies or agreeing with everything. Challenge errors with concrete evidence.
- Provide copy/paste-ready prompts, name the correct Cursor mode, and briefly explain why. Do not keep re-asking already answered questions. Avoid repeated "one last thing" surprises.

Ask vs Plan vs Agent and Build button

- Ask mode: Read-only audits, PRD interpretation, comparing evidence, diagnosis, reviewing diffs, identifying blockers. State explicitly: do not modify files, run paid calls, commit, or push when applicable.
- Plan mode: Only for genuinely complex architectural or multi-file changes where reviewing the plan adds value. Ask Cursor to create or revise the plan, NOT "implement", "proceed" or "build". The user has a Build button and will press it when satisfied.
- Agent mode: Bounded implementation, test execution, targeted fixes, docs updates, git staging/commits only when expressly authorized. Prompts should preserve existing working behavior and scope.
- Do not invent extra project phases. C0-C5 were internal conveniences, not official milestones. Derive a small, PRD-mapped implementation plan only after reading Week 3 PRD. No redundant replanning once work is underway.

PRD-first completeness and evidence discipline

- Read the entire Week 3 PRD at the start. Extract every applicable engineering requirement into a traceability checklist: requirement → implementation location → verification method → evidence → PASS/FAIL/UNVERIFIED. Distinguish mandatory, optional/stretches, and cohort-only deliverables. Confirm with user if genuinely ambiguous.
- Do not repeat the Project 2 failure: CI lint/typecheck/coverage/security scope and performance/resource/cost reports were missed until the end of C5, despite repeated PRD review. Track cross-cutting engineering obligations from day one and verify before declaring complete.
- Never label a feature "100% compliant" from a green smoke test. Differentiate implemented, locally tested, browser-tested, live-model tested, and GitHub Actions verified. If unverified, say so without manufacturing evidence.
- Treat real outputs and PRD text as authoritative; do not blindly trust Cursor/Grok summaries. When an audit claims "not tested", reconcile with existing screenshots, logs and prior results before commissioning duplicate tests.
- One final PRD audit at end, not endless shifting audits or surprise scope. Mandatory blockers only; document nonblocking measurement limitations. Do not move goalposts after declaring requirements satisfied.

Testing, model calls, security and local state

- Use free stub/unit/integration checks first. For paid OpenRouter calls, use the authorized Gauntlet key carefully, minimum defensible samples, record estimated vs

verified costs, and avoid duplicate runs. User has permitted controlled paid testing, not unlimited experimentation.

- Preserve original live agent, patient data, persistent volumes, HMAC audit chain and working public demo. Prefer isolated real-model containers and synthetic fixtures. Never mutate live patient data, credentials, routing or production config without explicit approval.
- Security: never paste, print or commit keys, passwords, tokens, local .env, session cookies or PHI. Review staged diff, generated files and ignored secrets before pushing. Keep synthetic test data separated from real data.
- Manual browser acceptance is for end-to-end behavior, citations, PDF highlighting and ACL, not for every CI-only edit. CI checks should be verified by actual GitHub Actions, not merely local green reports. When CI fails, investigate real cause; do not hide or skip failures to get green.

Git, branch hygiene and merging

- Never commit, push, merge, delete branches, reset local work, or change protected settings without the user authorizing that action. Cursor can stage for review when asked. Keep regenerated evaluation outputs out of unrelated commits; preserve tracked baseline evidence.
- Project 3 branch should start from Sabeehq11:main after pulling the merged Week 2 state. Do not accidentally open PR against Gauntlet-HQ:main . Check owner, base, compare, commit count, file count and CI before merging.
- PR workflow: review staged diff → user authorizes commit/push → inspect GitHub Actions → PR to fork main → wait for required PR checks → merge only after user confirmation. Post-merge status may run again; do not confuse PR green with post-merge green.

Decision-making and scope

- Prioritize real mandatory engineering work over polish. Avoid excessive UI styling, unrelated refactors, or third-party upgrades while closing PRD gates. When a defect is found, propose the smallest verified fix.
- No invented requirement for cohort demo videos, public social posts or other submission artifacts unless Week 3 PRD and user-specific assignment make them applicable. Public deployment may be useful, but distinguish temporary quick tunnels from durable URLs.
- If user is tired or frustrated, give a single concrete next action, not a cascade of new phases. Report genuine blockers early. Do not call a project done until checklist and evidence agree.

9. Recommended Project 3 opening procedure

- User attaches Week 3 PRD and this handoff PDF in a fresh ChatGPT chat. Read both completely. Do not assume Week 3 is simply Week 2 plus another feature.

- Confirm current fork main and local git status; note outstanding generated eval files and local DEMO_SCRIPT edit. Check whether post-merge main CI is green if relevant, but do not stall new project without a genuine blocker.
- Produce concise Week 3 requirement matrix and phased implementation approach mapped to actual PRD; account for testing, CI, performance, security, cost and deploy from the beginning. User reviews; use Cursor Plan mode only when necessary.
- Create a new feature branch from updated fork main with user authorization. Preserve Week 1/2 functionality and isolated real-model setup. Verify PRD gates incrementally.

10. Suggested first message for new ChatGPT conversation

Copy the starter prompt supplied alongside this PDF in the current chat. The new assistant should ask for the Week 3

PRD only if it is not attached, and should not invent requirements.

Evidence note: This handoff consolidates the original Project 1 PDF, the Project 2 reports pasted in the conversation, and user screenshots. It is not an independent live inspection of the repo. Dates, URLs and local process state may change.